



SIMATS
ENGINEERING



SIMATS
Saveetha Institute of Medical And Technical Sciences
(Declared as Deemed to be University under Section 3 of UGC Act 1956)

CO5 ASSESSMENT TOOL 2

Name : S.Deepadharshan

Reg No : 192472046

Course Code : ITA1408

Course Name : Ethical Hacking

Submitted to : Dr Parthiban S

APPLICATION-BASED QUESTION

QUESTIONS

1. Evaluate how attackers could exploit exposed RPC vulnerabilities in legacy Windows servers to gain unauthorized access and escalate privileges. Assess the risks of delayed patching and recommend suitable mitigation strategies without affecting business continuity.
2. Evaluate how attackers could combine XSS, CSRF, and weak session management vulnerabilities to affect user accounts. Assess the associated risks and recommend a layered security approach to secure the web application.
3. Assess how attackers could exploit unpatched vulnerabilities in an outdated IIS server to gain unauthorized access or execute remote code. Evaluate the risks of delayed updates and recommend strategies to maintain both security and service availability.
4. Evaluate how plaintext storage of sensitive information and unsecured communication in a mobile application could be exploited. Assess the impact on user privacy and recommend secure storage and communication techniques.
5. Evaluate how disabling the Windows firewall could expose critical services to unauthorized access. Assess the risks of mismanaging security controls and recommend automated policies and administrative safeguards to prevent such incidents

QUESTION 1

RPC Vulnerabilities in Legacy Windows Servers

Introduction

The organization operates legacy Windows servers with multiple exposed RPC services. Delayed patching has increased the attack surface, while abnormal traffic and unauthorized connection attempts indicate a potential security risk.

Analysis

Remote Procedure Call (RPC) allows systems and applications to communicate with services running on other systems. When RPC services are exposed and remain unpatched, attackers may take advantage of known security weaknesses to gain unauthorized access.

An attacker may first identify exposed RPC services and determine whether they are vulnerable. If a vulnerable service is successfully compromised, the attacker may obtain unauthorized access to the server. If the compromised service operates with elevated privileges, the impact can become more serious because the attacker may gain access to sensitive resources or perform unauthorized administrative actions.

Delayed patching increases the period during which known vulnerabilities remain exploitable. In a financial organization, this can result in data exposure, service disruption, unauthorized modification of systems, and further compromise of connected resources.

Risk Assessment

The risk associated with delaying patches is high because:

- Legacy systems may contain known vulnerabilities.
- Exposed RPC services increase the attack surface.
- Abnormal traffic suggests possible reconnaissance or attack activity.
- Successful compromise could affect critical financial applications.
- A compromised server could become a starting point for further attacks.

Immediate Patching vs Controlled Maintenance

Immediate patch deployment is preferable when a critical vulnerability is actively exposed or exploitation is suspected. However, business-critical systems may require testing before patches are deployed.

A controlled maintenance approach with urgent prioritization is therefore appropriate. Critical patches should first be tested in a controlled environment and then deployed using a phased rollout, while temporary protections are applied to systems that cannot be patched immediately.

Mitigation Strategies

1. Apply security patches according to vulnerability severity.
2. Disable unnecessary RPC services.

3. Restrict RPC access using firewalls and network segmentation.
4. Monitor abnormal RPC traffic and connection attempts.
5. Maintain updated asset and vulnerability inventories.
6. Use backups and recovery procedures before major maintenance.
7. Establish an emergency patching procedure for critical vulnerabilities.
8. Regularly perform vulnerability assessments.

Conclusion

Delaying patches on exposed legacy Windows servers creates significant security risks. The organization should prioritize critical patches while using controlled deployment and temporary network restrictions to maintain business continuity.

QUESTION 2

XSS, CSRF and Weak Session Management in a Web Application

Introduction

The web application is used for online transactions and suffers from XSS, CSRF, and weak session management. Unauthorized transactions and session hijacking indicate that these vulnerabilities can have a direct impact on user accounts and financial activities.

Analysis

Cross-Site Scripting (XSS) occurs when untrusted input is included in a web page without proper validation or output encoding. Malicious script content may then execute in a user's browser.

Cross-Site Request Forgery (CSRF) causes a user's browser to send an unwanted request to a web application while the user is authenticated.

Weak session management occurs when session identifiers are poorly protected, predictable, insufficiently expired, or inadequately invalidated.

These vulnerabilities can become more dangerous when combined. For example, XSS can affect actions performed within a user's browser, while weak session controls can increase the consequences of session compromise. CSRF can further increase the risk of unauthorized actions when the application does not properly verify that requests originated from the legitimate application interface.

Risks

The major risks include:

- Unauthorized transactions
- Account takeover
- Session hijacking

- Modification of user information
- Exposure of confidential information
- Financial loss
- Loss of customer trust
- Legal and reputational consequences

Need for Layered Security

A layered security approach is necessary because fixing only one vulnerability does not eliminate the complete attack path. Security should be implemented at the input, application, session, authentication, and monitoring levels.

Mitigation Strategies

1. Validate and sanitize all untrusted input.
2. Apply context-appropriate output encoding to prevent XSS.
3. Use anti-CSRF tokens for state-changing requests.
4. Use secure, unpredictable session identifiers.
5. Enable appropriate Secure, HttpOnly, and SameSite cookie protections.
6. Expire and invalidate sessions appropriately.
7. Re-authenticate users for highly sensitive transactions.
8. Implement strong authentication and access controls.
9. Monitor unusual account and transaction activity.
10. Perform regular security testing of the application.

Conclusion

The combination of XSS, CSRF, and weak session management can seriously affect user accounts and transactions. A layered security strategy combining secure coding, strong session controls, request validation, authentication, and continuous monitoring is essential.

QUESTION 3

Security Risks of an Outdated IIS Server

Introduction

The organization uses an outdated IIS server for internal and external applications. Vulnerability scans have identified several unpatched critical flaws, but updates have been delayed because of concerns about downtime.

Analysis

Internet-facing IIS servers are important entry points into an organization's infrastructure. When critical vulnerabilities remain unpatched, attackers may attempt to exploit weaknesses in the server, applications, or installed components.

A successful vulnerability exploitation could result in unauthorized access, compromise of application data, disruption of services, or in severe cases, remote code execution. Remote code execution is particularly dangerous because it may allow unauthorized commands or operations to be performed on the affected server.

The longer security updates are delayed, the greater the exposure period becomes. This is especially serious when the vulnerabilities are publicly known and security updates are already available.

Risk Assessment

The major risks include:

- Unauthorized server access
- Remote code execution
- Web application compromise
- Data exposure
- Service disruption
- Malware installation
- Further compromise of connected systems
- Loss of customer confidence

Immediate Patching vs Temporary Isolation

For critical vulnerabilities on externally accessible servers, immediate remediation should be prioritized.

If immediate patching cannot be performed safely, temporary isolation can reduce exposure. The server may be restricted from unnecessary network access while the organization tests and prepares the required updates.

The preferred approach is therefore:

Temporary isolation where necessary + urgent patch testing + controlled deployment.

Strategies for Security and Availability

1. Test patches in a staging environment.
2. Maintain reliable backups before deployment.
3. Use phased patch deployment.
4. Schedule maintenance during low-traffic periods.

5. Restrict unnecessary external access.
6. Monitor IIS logs and security events.
7. Remove unnecessary services and modules.
8. Maintain a vulnerability management process.
9. Prepare rollback procedures.
10. Continuously scan for newly discovered vulnerabilities.

Conclusion

Delaying critical security updates creates substantial risk for an outdated IIS server. Immediate patching should be the preferred solution, while temporary isolation can be used when patching cannot safely occur immediately. Proper testing, backups, monitoring, and phased deployment can reduce downtime while maintaining security.

QUESTION 4

Security of Sensitive Data in a Mobile Application

Introduction

The mobile application stores login credentials and personal information in plaintext on the device and communicates with backend servers through unsecured channels. These weaknesses can expose sensitive information to unauthorized parties.

Analysis

Storing sensitive information in plaintext means that anyone who gains inappropriate access to the device or its application storage may potentially read the stored information.

The use of unsecured communication between the mobile application and backend servers creates another major risk. Information transmitted between the application and server may be exposed through network interception, particularly when adequate transport security is not used.

These two weaknesses create risks both at rest and in transit.

Impact on User Privacy

If credentials or personal information are exposed, attackers may potentially gain unauthorized access to user accounts or misuse personal information.

Possible consequences include:

- Credential exposure
- Account compromise
- Personal data leakage
- Identity-related fraud

- Unauthorized transactions
- Loss of customer trust
- Regulatory and legal consequences
- Damage to organizational reputation

Importance of Encryption

Encryption protects sensitive information by converting readable information into protected data that cannot be easily understood without the appropriate cryptographic key.

Encryption should be applied to both:

- **Data at rest** – information stored on the device.
- **Data in transit** – information transferred between the application and backend server.

Secure Storage Techniques

1. Avoid storing unnecessary sensitive information.
2. Use platform-provided secure storage mechanisms.
3. Encrypt sensitive locally stored data.
4. Never store passwords in plaintext.
5. Use secure credential/token management.
6. Apply appropriate access controls.
7. Protect cryptographic keys using secure platform mechanisms.

Secure Communication Techniques

1. Use HTTPS with modern TLS.
2. Validate server certificates properly.
3. Avoid transmitting sensitive information over unsecured channels.
4. Apply secure authentication mechanisms.
5. Protect session tokens.
6. Monitor communication-related security events.
7. Keep mobile and backend components updated.

Conclusion

Plaintext storage and unsecured communication create serious privacy and security risks. The application should minimize stored sensitive information, use secure device storage and encryption, and communicate with backend services using properly configured secure transport.

QUESTION 5

Security Risks of Windows Firewall Mismanagement

Introduction

The system administrator temporarily disables the Windows firewall to troubleshoot connectivity problems but fails to re-enable it. Shortly afterward, unauthorized access attempts are detected. This demonstrates the security risk created by improper management of security controls.

Analysis

A firewall controls network traffic according to defined security rules. When the Windows firewall is disabled, network services that would normally be protected may become accessible to unauthorized systems.

Attackers monitoring the network may identify accessible services and attempt unauthorized connections. If an exposed service contains a vulnerability or uses weak authentication, the attacker may potentially gain unauthorized access.

The incident also demonstrates that a temporary security change can become a permanent vulnerability when it is not properly reversed.

Risks of Firewall Mismanagement

The major risks include:

- Increased network exposure
- Unauthorized connection attempts
- Exposure of critical services
- Increased attack surface
- Potential malware infection
- Unauthorized access to systems
- Difficulty maintaining consistent security policies

Importance of Automated Policies

Automated security policies reduce dependence on human memory. If a firewall is disabled temporarily, an automated policy can ensure that the firewall is automatically restored according to predefined security requirements.

Centralized security management can also ensure that systems maintain approved configurations and alert administrators when security controls are changed.

Administrative Safeguards

1. Require authorization before disabling security controls.
2. Record the reason and duration of temporary changes.

3. Use automatic restoration policies.
4. Implement configuration monitoring.
5. Generate alerts when the firewall is disabled.
6. Apply the principle of least privilege.
7. Maintain centralized firewall management.
8. Conduct regular security configuration audits.
9. Establish change-management procedures.
10. Provide security awareness training to administrators.

Recommended Approach

The organization should adopt a deny-by-default security posture where unnecessary network connections are blocked. Temporary changes should have an approved duration and should automatically revert after troubleshooting.

Firewall status should also be continuously monitored so that administrators are immediately alerted when an important security control is disabled.

Conclusion

Disabling a firewall without restoring it can significantly increase system exposure. Automated security policies, centralized monitoring, access controls, and formal change-management procedures can prevent similar incidents and ensure that security controls remain active.

OVERALL CONCLUSION

The five application-based scenarios demonstrate the importance of proactive vulnerability management and layered security. Exposed RPC services, vulnerable web applications, outdated IIS servers, insecure mobile applications, and improperly managed firewalls can all create significant security risks.

Effective cybersecurity requires timely patching, secure configuration, encryption, strong authentication, network controls, continuous monitoring, automated security policies, and regular security assessment. A defense-in-depth approach helps organizations reduce vulnerabilities while maintaining availability and business continuity.